

■■■■■■■■ ■■■■■■■■ ■■■■■

RESERVE BANK OF INDIA

Department of Information Technology
Central Office, Mumbai - 400001

RBI/2026-27/42

DIT.CO.CSEC/2026-27/1042

June 1, 2026

The Chairman / Managing Director / Chief Executive Officer
All Scheduled Commercial Banks
All Payment System Operators

Re: Master Directions on Cyber Security, IT Governance, and Operational Resilience Framework for Regulated Entities — Revised Guidelines 2026

Dear Sir / Madam,

In view of the evolving cyber threat landscape and the increasing digitization of banking services, the Reserve Bank of India has reviewed the existing framework for cyber security and IT governance. Based on feedback from regulated entities, international best practices, and recommendations of the Standing Committee on Cyber Security, the following revised guidelines are hereby issued for compliance by all scheduled commercial banks and payment system operators.

1. Vulnerability Assessment and Penetration Testing (VAPT)

All scheduled commercial banks shall conduct Vulnerability Assessment and Penetration Testing (VAPT) of their core banking systems, internet banking platforms, and mobile banking applications at least once every six months. The VAPT shall be conducted by CERT-In empanelled auditors. Reports must be submitted to the Chief Information Security Officer (CISO) within 15 days of completion. Any critical vulnerabilities identified must be remediated within 30 days of discovery.

2. Enhanced Customer Due Diligence (CDD)

Banks shall implement enhanced due diligence procedures for accounts classified as high-risk under the risk-based approach. This includes: (a) periodic review of KYC documents every 6 months instead of annually; (b) transaction monitoring with automated alerts for unusual patterns; (c) mandatory senior management sign-off for accounts exceeding ₹50 lakhs in aggregate quarterly transactions; and (d) enhanced screening against updated sanctions lists and PEP databases on a real-time basis.

3. Cyber Incident Reporting Framework

All regulated entities must report cyber security incidents to RBI's Cyber Security Incident Reporting (CSIR) portal within 6 hours of detection. A detailed incident report including root cause analysis, impact assessment, and remediation steps must be submitted within 72 hours. Banks must maintain a dedicated Cyber Security Operations Centre (CSOC) operational 24x7 with at least Level 2 SOC analyst coverage. Quarterly drill exercises simulating cyber attack scenarios are mandatory.

4. Operational Risk Capital Adequacy — Revised Approach

Banks shall recalculate operational risk capital requirements using the revised standardized approach effective from the reporting quarter ending September 2026. The Basic Indicator Approach (BIA) multiplier has been revised from 15% to 18% of gross income averaged over the previous three years. All internal models used for operational risk assessment must be re-validated by an independent validation unit and approved by the Risk Management Committee of the Board before implementation.

5. Data Localization and Cross-Border Data Transfer

All payment system data including full end-to-end transaction details, customer information, and payment credentials shall be stored exclusively in systems and data centers located within India. Banks currently storing any payment-related data in overseas facilities shall complete migration to domestic data centers within 6 months from the date of this circular. A compliance certificate signed by the CISO must be filed with the Department of Payment and Settlement Systems on a quarterly basis.

6. Branch Audit Trail Digitization

All bank branches shall maintain digital audit trails for: (a) cash transactions exceeding ₹10 lakhs; (b) foreign exchange transactions irrespective of value; (c) demand draft issuances above ₹5 lakhs; and (d) any transaction flagged by the automated monitoring system. The digital records must be tamper-proof, time-stamped with NTP-synchronized clocks, and retained for a minimum period of 10 years. Integration with the central audit management system is mandatory within 150 days.

Compliance Timeline

Section	Requirement	Deadline
1. VAPT	First assessment under new frequency	90 days
2. Enhanced CDD	Process deployment	60 days
3. Cyber Reporting	C-SOC operationalization	45 days
4. Risk Capital	Recalculation submission	120 days
5. Data Localization	Complete data migration	180 days
6. Audit Digitization	System integration	150 days

This circular is effective immediately. Non-compliance will be viewed seriously and may attract supervisory action under the provisions of the Banking Regulation Act, 1949.

Yours faithfully,

(Rajesh Kumar Sharma)

Chief General Manager
Department of Information Technology